Applied Security Lab Write-Up

Unreviewed Break-Glass Exclusion in a Conditional Access Policy

Lab title	Unreviewed Break-Glass Exclusion in a Conditional Access Policy
Author	Wafula Mwangi
Environment	Microsoft 365 E5 trial tenant — wafulamwangi.onmicrosoft.com
Date	October 2026
Target platform	Microsoft Entra ID — Conditional Access
Classification	Internal lab exercise

1. Executive Summary

This lab examines a common and often-overlooked Microsoft Entra ID misconfiguration pattern: a standing, unreviewed exclusion on a tenant-wide Conditional Access policy. A "Require MFA for all users" policy was built targeting all users in the tenant, with two accounts excluded. The acting administrator (a standard, Microsoft-recommended safety exclusion to avoid lockout during testing) and a second, dedicated "break-glass" administrator account intended to represent an emergency-access account that, in practice, is frequently created once and never revisited.

Using the policy's Report-only evaluation mode, sign-in activity was generated for both an in-scope user and the excluded break-glass account. The resulting sign-in logs confirm the policy evaluates and would enforce MFA for ordinary users, while the excluded account's sign-in bypasses the policy entirely — producing no evaluation record at all, and therefore no signal that would prompt a reviewer to question whether that exclusion is still appropriate.

2. Scenario

Emergency-access ("break-glass") accounts are a legitimate and widely recommended Entra ID pattern: Microsoft itself advises maintaining one or two such accounts, excluded from Conditional Access, so that administrators are never fully locked out of the tenant. The risk is not the pattern itself, but how it is operated in practice. These accounts are commonly created during initial tenant setup, excluded from every policy "to be safe," and then left unreviewed indefinitely. An attacker who identifies such an account (through reconnaissance, a leaked credential, or insider knowledge) inherits a standing bypass of every Conditional Access control in the tenant, with no additional technique required.

This lab models that exact posture: a break-glass account ("Second Admin") is excluded from a tenant-wide MFA requirement alongside the day-to-day administrator account, and the resulting gap is demonstrated and evidenced at the sign-in log level.

3. Build

A Conditional Access policy was created with the following configuration:

- Name: Require MFA for all users
- Assignment to Include: All users
- Assignment to Exclude: Kevin Wafula (acting administrator, standard lockout-prevention exclusion) and Second Admin (break-glass account, the account under test)
- Target resources: All resources (formerly 'All cloud apps')
- Grant control: Require multifactor authentication
- State: Report-only (policy is evaluated but not enforced which is safe for lab testing without risking a lockout)



Figure 1 — Policy details: Report-only state, All users included, 2 users excluded

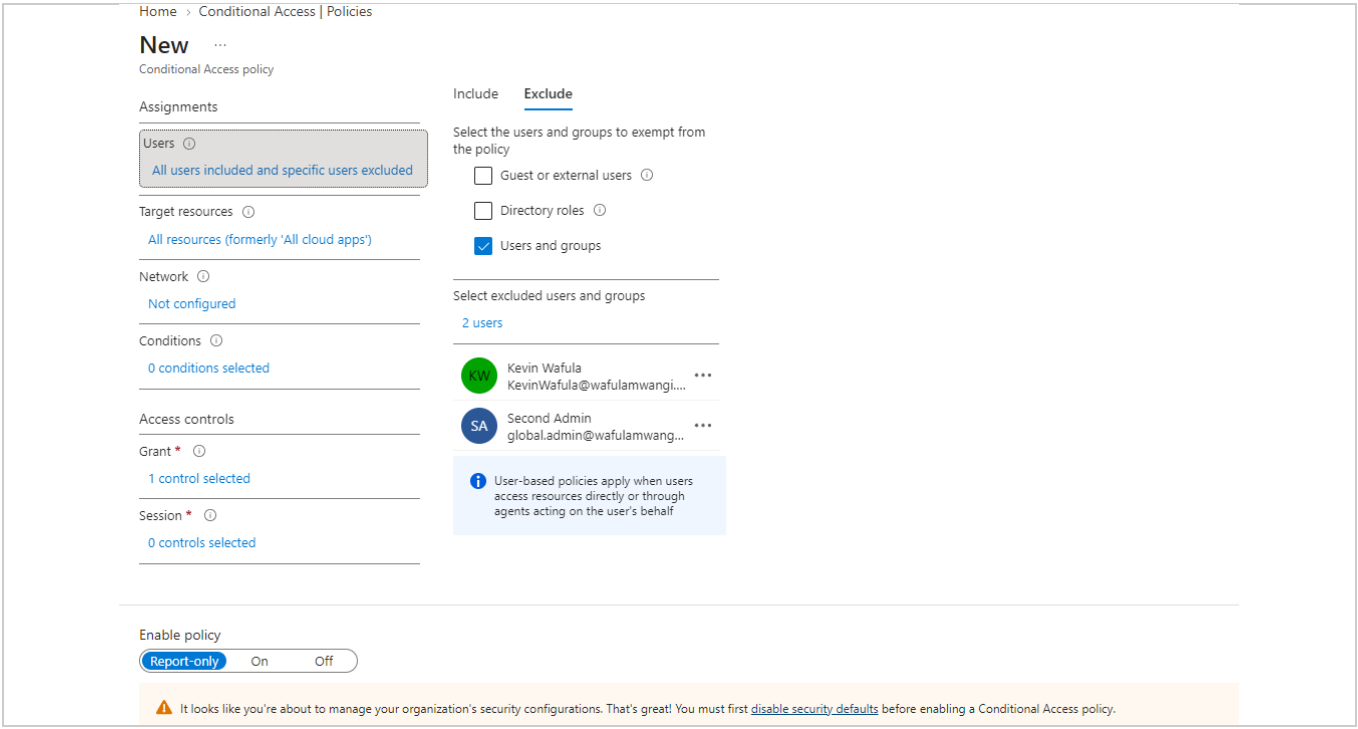


Figure 2 — Exclusion list: Kevin Wafula and Second Admin both excluded from the policy

4. Attack Narrative on Generating and Comparing Sign-In Evidence

With the policy active in Report-only mode, sign-in events were generated for two accounts: Finance Admin (an ordinary in-scope user) and Second Admin (the excluded break-glass account). Both sign-ins were then located in Entra ID Sign-in Logs and inspected via each event's Report-only evaluation tab, which shows how every Conditional Access policy in the tenant evaluated against that specific sign-in.

4.1 In-scope user whether policy evaluates and would enforce MFA

Finance Admin's sign-in shows the "Require MFA for all users" policy evaluated, with grant control "Mfa" and a result of Report-only: User action required. Meaning that, had the policy been enforced rather than report-only, this sign-in would have been challenged for multifactor authentication.

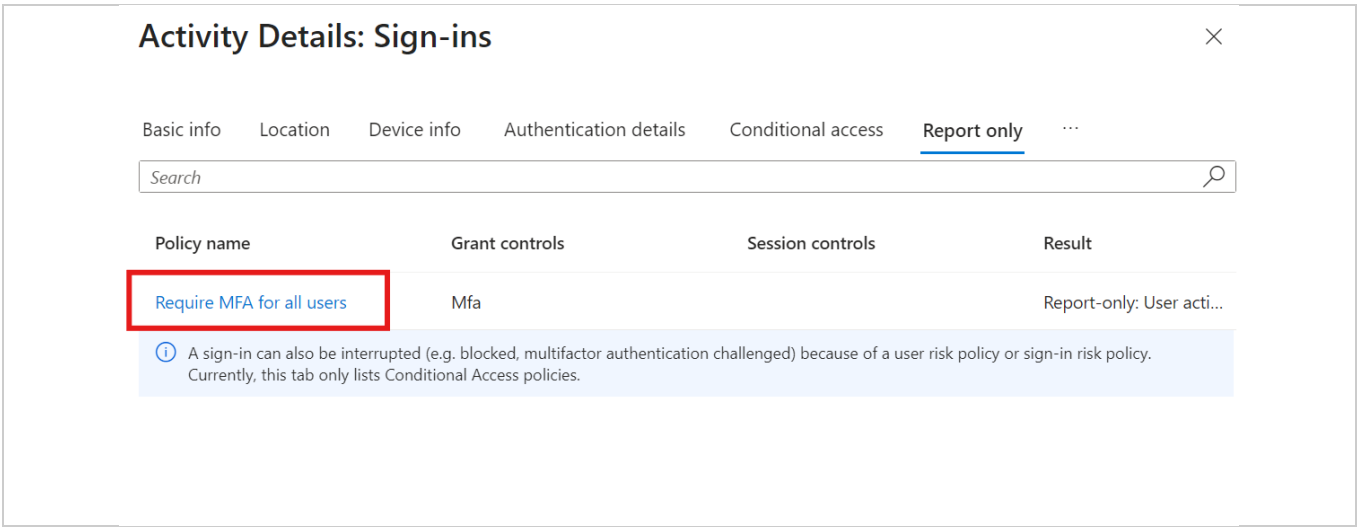


Figure 3 — Finance Admin sign-in: policy evaluated, Report-only: User action required

4.2 Excluded break-glass account: policy never evaluates

Second Admin's sign-in, occurring at a comparable point in time via the same authentication flow, shows the identical policy with a result of Report-only: Not applicable. The policy did not simply pass or allow this sign-in, it was never evaluated against it at all, because the account is named directly in the policy's exclusion list.

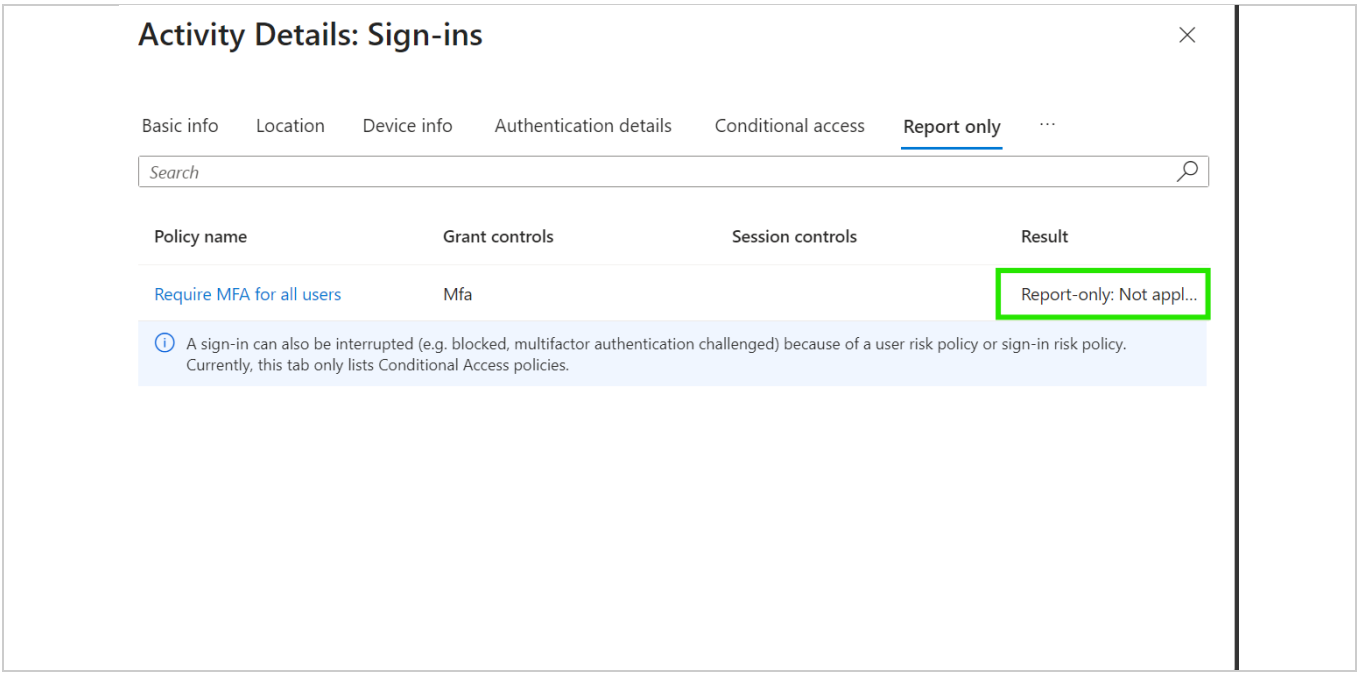


Figure 4 — Second Admin sign-in: Report-only: Not applicable — exclusion confirmed at the log level

This pairing is the core finding: identical policy, identical point in time, two entirely different evaluation outcomes determined solely by tenant group/user membership in a standing exclusion list that nothing in this workflow prompts anyone to revisit.

5. Impact

Any credential compromise, insider misuse, or social-engineering attack against the Second Admin account bypasses every control enforced by this Conditional Access policy — and, in a production tenant, likely every other Conditional Access policy that follows the same "exclude the break-glass account" pattern, since administrators typically apply the same exclusion consistently across all their policies. Because the exclusion produces no Conditional Access evaluation event at all (rather than a logged "bypassed" or "allowed" event), it is also less visible to log-based anomaly detection than a user who fails or passes an active policy check.

6. Detection

- Entra ID Sign-in Logs: sign-ins by accounts with standing Conditional Access exclusions show no entries, or "Not applicable" entries, under the Report-only / Conditional Access tab. Worth a standing query to enumerate which accounts never appear in policy evaluation results
- Entra ID Conditional Access - Insights and reporting: review the list of users excluded from each policy as a recurring, scheduled task rather than a one-time setup step
- Audit Logs: monitor for sign-in activity from designated break-glass accounts outside of planned testing or genuine emergency-access windows. Any such activity should trigger immediate investigation
- Entra ID Access Reviews: configure a recurring access review specifically scoped to Conditional Access policy exclusions, not just role or group membership

7. Remediation Recommendations

- Limit break-glass accounts to the minimum necessary (Microsoft recommends exactly two) and document their intended use explicitly
- Enable a recurring Entra ID Access Review on Conditional Access exclusion lists, with a defined owner and cadence (e.g., quarterly)
- Monitor break-glass account sign-in activity with a dedicated, high-priority alert. Any sign-in outside a declared emergency or test window should be treated as a potential compromise
- Store break-glass credentials in a secured, access-logged vault (e.g., a PAM solution) rather than a standard password, and enforce FIDO2 or a strong non-phishable authentication method for these accounts specifically, even though they are excluded from the tenant-wide MFA policy
- Consider excluding break-glass accounts only from the specific policies where lockout risk is genuine (e.g., MFA enforcement), rather than reflexively excluding them from every Conditional Access policy in the tenant

8. Appendix — Evidence Index

- Figure 1 — Policy details: Report-only state, 2 users excluded
- Figure 2 — Exclusion list naming both excluded accounts
- Figure 3 — Finance Admin (in-scope) sign-in: policy evaluated, would enforce MFA
- Figure 4 — Second Admin (break-glass, excluded) sign-in: policy never evaluated